

Incident Response Plan

Enterprise response process with severity matrix and ransomware playbook

Purpose and Scope

This plan defines how the organization prepares for, detects, analyzes, contains, eradicates, and recovers from cybersecurity incidents affecting systems, users, vendors, or regulated information.

Roles and Responsibilities

Role	Responsibilities
Incident Commander	Owns severity, priorities, approvals, and executive updates
Security Lead	Directs technical investigation, containment, and evidence preservation
IT Operations	Restores systems, patches infrastructure, and validates recovery
Legal/Privacy	Determines notification and legal-preservation obligations
Communications	Coordinates internal and external messaging
Business Owner	Validates business impact and recovery acceptance

Incident Lifecycle

Phase	Required Actions
Preparation	Maintain contacts, tools, backups, logging, playbooks, and tabletop exercises.
Detection & Analysis	Validate alert, open incident record, assign severity, preserve evidence, and establish scope.
Containment	Isolate affected assets, disable compromised credentials, block indicators, and protect critical operations.
Eradication	Remove persistence, patch root cause, rotate secrets, and validate clean systems.
Recovery	Restore from trusted backups, monitor closely, confirm business acceptance, and document residual risk.
Lessons Learned	Complete after-action review within 10 business days and track corrective actions.

Severity Matrix

Severity	Example	Target Escalation
SEV-1 Critical	Ransomware, major data exposure, business outage	Immediate; executive and legal involvement
SEV-2 High	Confirmed compromise with limited spread	Within 30 minutes
SEV-3 Medium	Contained malware or suspicious access	Within 4 hours
SEV-4 Low	Policy violation or unsuccessful attack	Next business day

Ransomware Playbook

Disconnect affected systems without powering them off; disable compromised accounts; preserve volatile and disk evidence; activate backups and business continuity; identify initial access; block indicators; assess notification obligations; rebuild from trusted images; and conduct heightened monitoring after restoration.